

NEWSLETTER N. 518 of February 14, 2024

Employment Agencies: The Privacy Authority has approved the Code of Conduct

Online Dating: The Privacy Authority fines a dating site 200,000 euros

Medical prescriptions outside the office: a doctor fined

Healthcare: An aesthetic medicine center fined for privacy violations

Employment Agencies: The Privacy Authority has approved the Code of Conduct

Candidate data can only be collected from professional-type social channels

The Privacy Authority has approved the Code of Conduct promoted by Assolavoro, the National Association of Employment Agencies. The Code defines the “best practices” for the proper handling of data conducted within the framework of intermediation, research, and personnel selection activities. With the same provision, the Authority has accredited the Monitoring Body, an independent entity composed of three members, tasked with verifying compliance with the Code by its members and managing the resolution of complaints.

The Code, currently being published in the Official Gazette, introduces some significant provisions to protect candidates for job positions, also to prevent possible discrimination in access to the labor market. In particular, Agencies that adhere to the Code commit to process only data strictly necessary for establishing the employment relationship and must not

therefore conduct inquiries into the political, religious, or union opinions of workers or carry out pre-selections based on information regarding marital status, pregnancy, disability, even with the consent of the candidates.

In the phase preceding hiring, Agencies must not obtain information through the consultation of social profiles intended for interpersonal communication. Online information can only be collected if made available on social channels that are of a professional nature, and limited to only information related to the required competence.

Employment Agencies, moreover, will not be able to acquire professional references of the candidate from previous employers and communicate them to their clients, on whose behalf the search for personnel is conducted, without “prior explicit authorization from the candidate.”

And they will not be able to process, even with the consent of the candidate, information related to disciplinary offenses or judicial proceedings that have involved

them.

As for the delicate aspect of decisions based on automated processing, Agencies must conduct a detailed impact assessment and in the information provided to workers, clearly indicate the mechanisms underlying the automation and the periodic evaluations adopted to verify the reliability of the automated system.

In the case of fully automated processing, workers must always be guaranteed at least the right to obtain human intervention, to express their opinion, and to contest the decision.

Online Dating: The Privacy Authority fines a dating site 200,000 euros

The Privacy Authority has fined the operator of a well-known online dating site 200,000 euros for having violated the personal data of approximately 1 million registered users. This is the first time that the Authority has taken action against a dating site.

The decision, made following a complex investigative activity that also required an on-site inspection, revealed the illegality of the processing of users' data, including those related to preferences and sexual orientations.

Registration on the platform, which has about 5 million users worldwide (of which over one million with validated emails and nearly 10,000 with active paid subscriptions), required the entry of numerous data (meeting interest, country, region, city of residence, date of birth, email) and photos, which clients uploaded within their public profile or in the reserved area, without being provided with adequate information on how that data would be used. The information present on the platform did not in fact include any indication regarding the multiple and additional processing carried out by the company managing the platform for the provision of the offered services, nor information on the possibility for the interested parties to exercise the rights provided by privacy regulations, including the right to file a complaint with the Authority.

From the inspection carried out by the Authority, it also emerged that the site owner did not have a specific privacy policy regarding the retention periods of processed data, limiting itself to randomly deleting inactive accounts and the information contained therein, as well as unsuccessful registration requests.

Finally, the company, despite being required to do so, had not

****Drafted the register of processing activities,****

had not appointed the data protection officer (DPO), nor had it prepared the impact assessment (DPIA) required by the European Regulation. In light of the numerous violations found, the Authority, in addition to the monetary sanction, ordered the adoption of a series of corrective measures aimed at bringing the processing activities into compliance with privacy regulations. The company, in particular, in addition to identifying retention periods for the personal information processed, to deleting user profiles whose retention is deemed excessive, and to drafting the impact assessment, must equip itself with systems aimed at strengthening the security of customer data, such as, for example, encryption measures or pseudonymization of sensitive data, timestamped log files, and intrusion detection systems.

****Medical prescriptions outside the office: a doctor sanctioned****

He left prescriptions for his patients in a container placed on the outer wall of the medical office, without even protecting them with closed envelopes. In this way, anyone could freely open the container and know the content of the prescriptions. For this reason, the fine from the Personal Data Protection Authority was triggered, sanctioning a doctor for 20,000 euros. The investigation by the Authority began following an assessment by the N.A.S. (Carabinieri for Health Protection) who also collected testimonies from some of the doctor's patients, some of whom were identified among those who had retrieved prescriptions from the container. In response to the Authority's request for information, the doctor justified himself by stating that the method of delivering prescriptions had been implemented during the Covid period and had then been maintained for several months, with the consent of the patients, in order to facilitate the collection of prescriptions and limit patient access to the medical office. In its sanctioning provision, the Authority reiterated that health-related information can indeed be communicated to third parties, but only on the basis of a suitable legal basis or with the written consent of the data subject, and in any case, it can never be disseminated. The Authority also reiterated what it had already stated in the past, namely that medical prescriptions can be left at pharmacies and medical offices, provided they are placed in a closed envelope, but leaving them unattended and accessible to all violates patient privacy because it allows the dissemination of data capable of revealing their health status. In determining the amount of the sanction at 20,000 euros, the Authority took into account, among other things, the large number of patients involved, the duration of the violation, which was established to be about two months, and the uncooperative behavior of the doctor during the investigation.

****Healthcare: Aesthetic medicine center sanctioned for privacy violation****

On the social profile of the facility, the recognizable face of a patient

Recognizes his own face in a video posted on the social profile of the aesthetic medicine center where he underwent some treatments on his nose. He turns to the Privacy Authority, which sanctions the medical center with a fine of 8,000 euros for unlawful processing of health data. The Authority established that the video, posted by the medical center for promotional purposes, featured the recognizable face of the patient for more than 30 seconds, without the individual having given specific consent for the filming and its dissemination. Furthermore, the video remained online accessible to anyone for 45 days before being removed by the medical center following the patient's request for deletion. With the sanctioning provision, the Authority reiterated that particular attention must be paid when disseminating images and information related to clinical cases for promotional or scientific purposes. Before doing so, it is always necessary to ensure that the patient has been informed in advance, has given specific consent, or that their data has been anonymized. The Authority, while reminding that in this context, without the consent of the data subject, the video dissemination of any information regarding health status is prohibited, therefore imposed a sanction of 8,000 euros on the medical center for unlawful processing of health data. The Authority also ordered the healthcare facility to adopt corrective measures to align the information with privacy regulations.

****THE ACTIVITIES OF THE AUTHORITY - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and provisions recently adopted by the Authority

Artificial intelligence: the Privacy Authority supports international dialogue – Press release of February 10, 2024

Driver data in the UK, Privacy Authority: issue already on the Authority's agenda – Press release of February 9, 2024

****NEWSLETTER of the Personal Data Protection Authority****

(Registered at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and editorial office: Personal Data Protection Authority, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it